SERVICENOW SYSTEM ADMINISTRATOR · NAAN MUDHALVAN (SMARTBRIDGE)

Problem-Solution Fit — Script-Controlled ACL (Restrict Record Access Based on Field Value)

Phase 3 · Project Design Phase

Deepak P (Team Lead) · Hemanthan B N · Ganesh A K · Irfan Rifayil Z

This document presents the Problem-Solution Fit canvas for the capstone project "Script-Controlled ACL: Restrict Record Access Based on Field Value," built on ServiceNow Personal Developer Instance dev443713.service-now.com (Australia family release). It maps the customer segments, their pains and triggers, the options available today, and how a field-value-driven Access Control List on the u_institution_details table delivers record-level access based on both the user's role and the Branch field value.

Project	Script-Controlled ACL — Restrict Record Access Based on Field Value
Instance	dev443713.service-now.com (ServiceNow PDI, Australia release)
Team	Deepak P (Lead), Hemanthan B N, Ganesh A K, Irfan Rifayil Z
Table in scope	u_institution_details (Institution Details)

1. Customer Segment(s) — CS

- ServiceNow administrator / builder — configures the table, roles and ACLs and owns platform security.
- Branch end-users, e.g. EEE User who holds roles bb1, bb2, bb3, bb4 — needs to manage only their own branch's student records.
- Institution data-security stakeholders — accountable for student data privacy and record integrity across ECE, EEE and CSE branches.

2. Problems / Pains — P

- Out of the box, any user who can reach the Institution Details table can read AND edit every record, regardless of branch.
- A branch user (EEE) can see and modify ECE and CSE records, breaking student data privacy.
- No field-value boundary exists, so record integrity depends on trust rather than enforced control.
- Access is all-or-nothing at the table level; there is no per-operation separation of read, create, write and delete.

3. Triggers to Act — TR

- A data-privacy requirement to keep each branch's student records visible only to that branch.
- Onboarding branch users who must be granted least-privilege access rather than blanket table access.
- An audit or review that surfaces cross-branch visibility as a compliance gap.

4. Available Solutions — AS (and their limits)

- A single table-level role (the auto-generated u_institution_details_user): grants everyone with the role full access to all rows, so it was removed.

- Separate copies of the table per branch: duplicates schema and data, hard to maintain and does not scale.
- Business Rules or query Business Rules alone: enforce filtering but sit outside the platform's native access-control engine and are easier to bypass.

5. Channels of Behaviour — CH

Online	ServiceNow UI list and form for u_institution_details; roles assigned via sys_user_has_role; verification via Impersonation.
Offline	Institution's internal expectation that branch staff only handle their own branch's student data.

6. Solution — SL

Implement four record-level, operation-specific ACLs on u_institution_details, one each for read, create, write and delete, driven by dedicated roles bb1-bb4. The READ ACL is set to Advanced, carries the data condition Branch is EEE, and runs a server-side GlideScript that returns true only for admin or bb1. Because access now depends on both the user's role and the Branch field value on the record, a branch user sees only their own branch. Editing ACLs required elevating to the security_admin role, and the default u_institution_details_user role was removed so each ACL needs only its bb role.

7. How the Script-Controlled ACL Fits

Operation	Required role	Data condition	Script	Resulting behaviour
Read	bb1	Branch is EEE (u_branch=EEE)	Advanced: returns true for admin, true for bb1, false otherwise	EEE User sees only EEE001 and EEE002 (2 of 2); no ECE/CSE rows
Create	bb2	None	None	Only bb2 holders can insert new Institution Details records
Write	bb3	None	None	Only bb3 holders can update an existing record
Delete	bb4	None	None	Only bb4 holders can delete a record

Fit confirmed by impersonation on 2026-09-28: EEE User (bb1-bb4) sees only the two EEE records with New, Update and Delete available; Abel Tuter (no bb roles) sees "Security constraints prevent access to requested page"; System Administrator (admin) sees all four records (ECE001, EEE001, EEE002, CSE001).